

基于大模型的攻击行为全方位检测、捕获与溯源系统

实验报告

课程名称：2026年春季学期《网络空间安全综合实验》

授课教师：崔宝江 教授

实验题目：基于大模型的攻击行为全方位检测、捕获和溯源

小组成员：（待填写）

提交日期：2026年7月

基于大模型的攻击行为全方位检测、捕获与溯源系统

实验报告

一、小组人员分工及工作量占比

二、实验背景与目标

2.1 实验背景

2.2 实验目标

三、系统总体架构

3.1 系统架构图

3.2 核心技术栈

3.3 数据流

四、内网环境搭建模块

4.1 网络拓扑设计

4.2 虚拟机配置表

4.3 防火墙策略

五、模块一：攻击行为检测（Detection）

5.1 多源数据接入

5.1.1 Windows Event Log（系统日志）

5.1.2 终端行为数据（HostBehaviors）

5.1.3 网络流量日志（NetworkTraffic）

5.2 异常检测：RAG + LLM 双引擎

5.2.1 规则引擎（快速通道）

5.2.2 RAG 检索增强生成

5.2.3 DeepSeek LLM 深度分析

5.3 威胁建模：ATT&CK 映射

5.4 告警分级

六、模块二：攻击行为捕获（Capture）

6.1 多智能体协作捕获框架

Agent 1: EvidenceCollector（证据收集）

Agent 2: ChainBuilder（攻击链构建）

Agent 3: Verifier（真伪验证）

Agent 4: Arbitrator（LLM 裁决）

6.2 攻击链重构

6.3 证据固化（SHA-256 哈希链）

七、模块三：攻击溯源（Attribution）

7.1 威胁情报融合

7.2 证据路径推理（TAA-EPLMR 风格）

7.3 攻击者画像

7.4 自动化报告生成

八、分析场景设计与验证

8.1 场景一：APT 全链条攻击检测与溯源

8.2 场景二：AI 智能体滥用行为检测与溯源

8.3 场景三：勒索软件/数据窃取事件溯源

8.4 真实端点行为验证

九、开源参考项目对比

十、实验过程与测试结果

10.1 测试环境

10.2 功能测试

10.3 性能测试

十一、开发编程项介绍

11.1 项目代码结构

11.2 关键代码量

十二、实验总结

12.1 主要成果

12.2 存在的不足与改进方向

12.3 心得体会

附录

A. 系统启动命令

B. SQL Server 建库脚本

C. 预设数据库连接

D. 演示视频录制要点

E. 参考资料

一、小组人员分工及工作量占比

姓名	学号	分工	工作量
(组长)		系统架构设计、LLM检测引擎、多智能体捕获框架、项目协调	25%
组员2		前端开发(Vue3 SPA)、数据可视化、场景管理	20%
组员3		行为监控Agent、SQL Server存储层、流量分析模块	20%
组员4		归因引擎、威胁情报整合、RAG知识库	20%
组员5		网络环境搭建、测试验证、文档撰写	15%

(待各组根据实际情况修改)

二、实验背景与目标

2.1 实验背景

网络攻击的形态正在发生深刻变革。攻击者正在从键盘前消失——云鼎实验室观测到一批真实攻击案例，涉及 Claude Code Agent、CyberStrike-AI、OpenClaw、OpenCode 等不同工具和框架，这些攻击案例有着共同的执行形态：攻击链里开始出现 LLM 生成的解释、代码、试错和路径切换。

APT 组织的攻击链通常涉及侦察、渗透、横向移动和数据外泄等多个阶段，采用隐蔽的命令与控制通信机制，长期潜伏以窃取数据或实施破坏。MITRE 知识库已将对手利用 AI 和 LLM 的行为从推测转为有记录、有归因的实际活动。

面对这一形势，传统的"检测-响应"模式已力不从心。大语言模型（LLM）强大的语义理解、多步推理和知识融合能力，为网络攻击的检测（Detection）、捕获（Capture）和溯源（Attribution）提供了全新的技术路径。

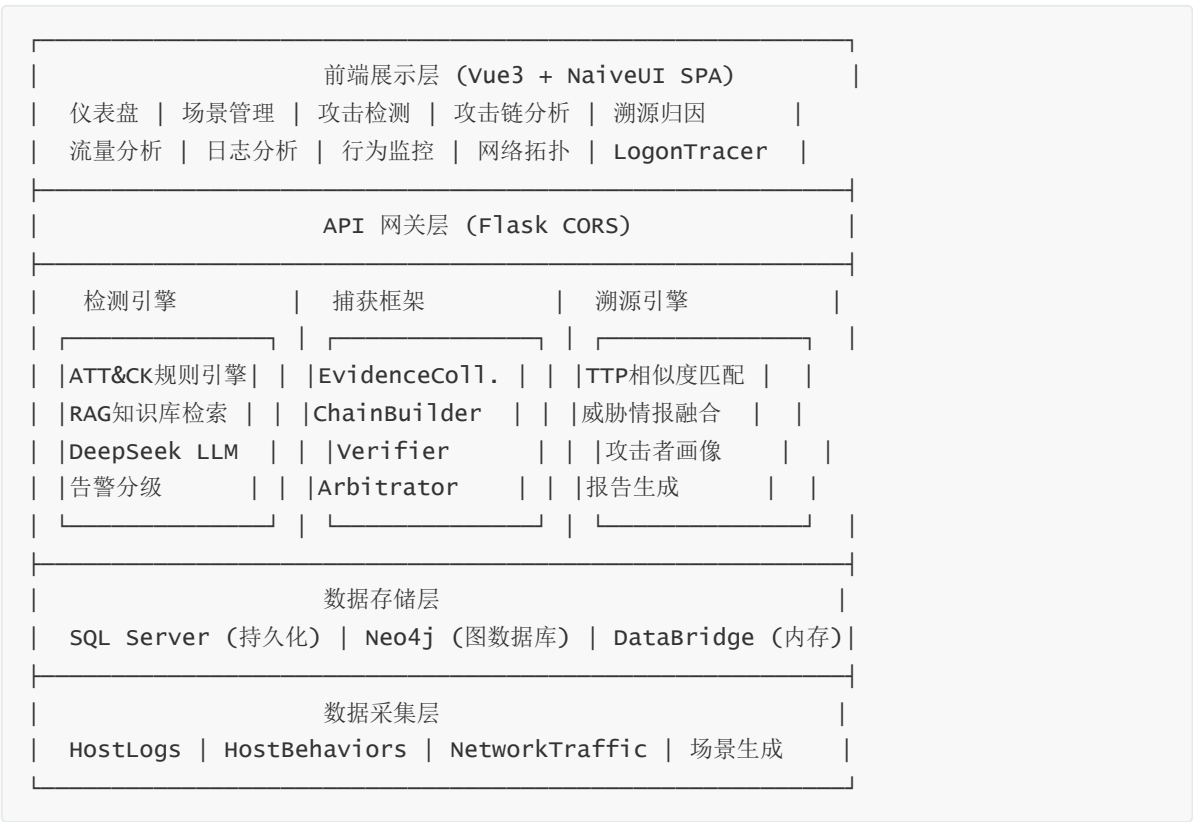
- **检测层面**：LLM-APTDS 等系统已利用多模型协同检测架构，通过 LLM 的语义理解实现对日志异常的精准定位；PROVSEEK 通过 LLM 驱动的智能体框架，在威胁检测任务上实现了 22%/29% 的精确率/召回率提升。
- **捕获层面**：智能体安全审计框架（如 AgentStalker）实现了端到端的攻击行为捕获——从静态建模到攻击图合成，再到沙箱动态验证与证据裁决的完整链路。
- **溯源层面**：TAA-EPLMR 提出了证据路径增强的 LLM 推理方法，将威胁情报知识图谱与 LLM 深度融合；HunterAgent 在反取证场景下实现了 86.1% 的平均 F1 值。

2.2 实验目标

1. 深入理解网络攻击（特别是 APT 攻击）的生命周期模型及其对应的 MITRE ATT&CK 框架
2. 掌握基于大语言模型的异常检测、威胁狩猎、攻击溯源等核心技术原理与实现方法
3. 构建一个覆盖"检测→捕获→溯源"三个环节的端到端攻击行为分析系统
4. 培养从真实攻击案例中抽象问题、设计系统化解决方案的工程与科研能力

三、系统总体架构

3.1 系统架构图



3.2 核心技术栈

层级	技术
前端	Vue 3 + TypeScript + Vite + Naive UI + Pinia + Vue Router
后端	Python Flask + flask-cors
LLM	DeepSeek API (OpenAI兼容)
数据库	SQL Server (持久化) + Neo4j (图) + DataBridge (内存降级)
知识库	MITRE ATT&CK + APT组织档案 + RAG TF-IDF检索
可视化	Cytoscape.js + Chart.js + SVG Canvas
流量采集	dumpcap + PcapParser
行为监控	Windows Event Log + pywin32 + psutil Agent

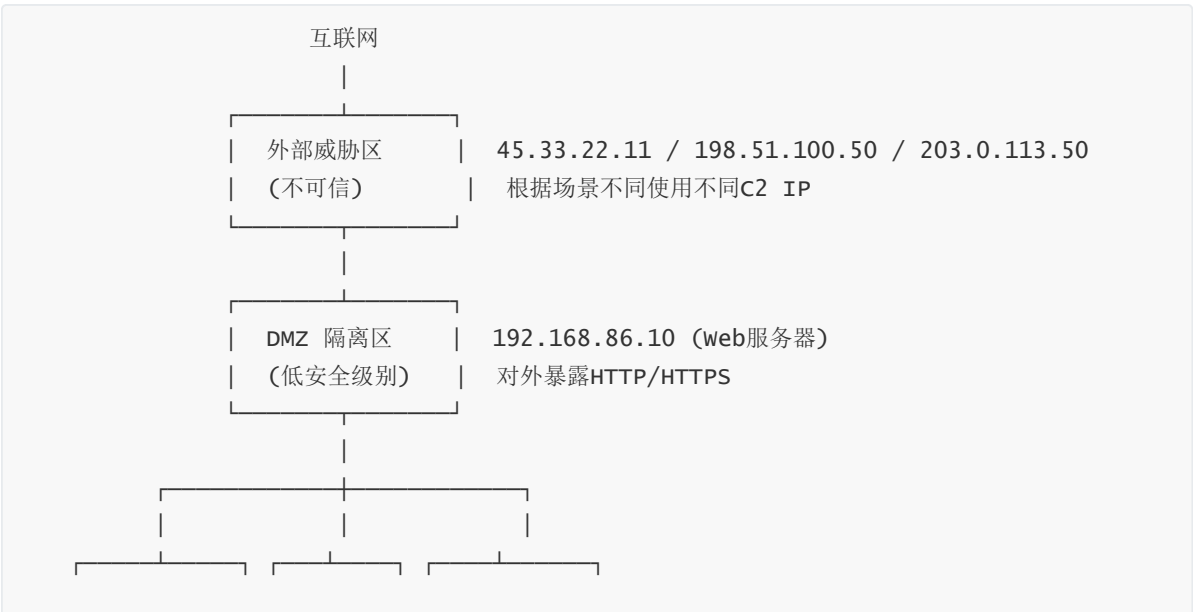
3.3 数据流



四、内网环境搭建模块

4.1 网络拓扑设计

本系统设计了包含 6 个节点、5 个安全区、2 层网络防御的企业网络拓扑：





4.2 虚拟机配置表

序号	主机名	IP地址	OS	角色	安全区	安全级别
1	web01-dmz	192.168.86.10	Ubuntu 22.04	Web服务器	DMZ	低
2	srv-core	192.168.86.130	Ubuntu 22.04	核心服务器	内网核心	中
3	dc-win	192.168.86.131	Windows Server 2022	域控制器	内网高安全	高
4	jump-host	192.168.86.132	Ubuntu 22.04	跳板机	内网	低
5	soc-node	192.168.86.200	Ubuntu 22.04	SOC分析节点	安全管理	最高
6	attacker	可变	Kali Linux	C2/攻击者	外部	不可信

4.3 防火墙策略

规则	源	目标	协议/端口	动作
DMZ→内网隔离	192.168.86.10	192.168.86.0/24	ALL	DENY
外部→DMZ Web	ANY	192.168.86.10	TCP/80,443	ALLOW
内网→DMZ	192.168.86.0/24	192.168.86.10	TCP/22	ALLOW
SOC→全网	192.168.86.200	ANY	ANY	ALLOW
外网→内网	ANY	192.168.86.0/24	ANY	DENY

五、模块一：攻击行为检测（Detection）

5.1 多源数据接入

系统支持三种数据源的接入与分析：

5.1.1 Windows Event Log（系统日志）

通过 `utils/winlog/collector_windows.py` 采集 Windows 安全事件日志，归一化后写入 SQL Server 的 `dbo.HostLogs` 表。

采集字段：

- Event ID（如 4624 登录成功、4625 登录失败、4688 进程创建）
- 时间戳（UTC）
- 用户名、源IP、会话ID
- 登录类型、进程名

采集方式：

```
# 以管理员权限运行
python app_launcher.py
# 在日志分析页点击"扫描服务器日志并入库"
```

5.1.2 终端行为数据（HostBehaviors）

通过 `utils/behavior_monitor/client_agent.py` 在客户端部署轻量级 Agent，实时监控：

事件类型	监控内容	Windows API
process_create	进程创建（进程名、PID、父进程、命令行）	WMI Event Subscription
file_create/modify/delete	文件操作	ReadDirectoryChangesW
network_connection	TCP/UDP 连接	psutil
dns_query	DNS 解析请求	Socket hooking
registry_set	注册表修改	win32api

Agent 部署命令：

```
python utils/behavior_monitor/client_agent.py --server http://10.21.233.136:5000
--verbose
```

5.1.3 网络流量日志（NetworkTraffic）

通过 Wireshark dumpcap 工具实时抓包，解析 pcap/pcapng 文件后入库：

- **在线抓包：**dumpcap 子进程持续写 pcapng → 停止后自动解析入库
- **离线导入：**支持上传 .pcap/.pcapng/.cap 文件
- **协议解析：**TCP/UDP/ICMP/DNS/HTTP/HTTPS

- **隧道检测**：DNS 隧道（熵值分析）、ICMP 隧道（载荷异常检测）、HTTP 隐蔽信道

5.2 异常检测：RAG + LLM 双引擎

5.2.1 规则引擎（快速通道）

系统内置 20 条 ATT&CK 映射规则（`attack_rules.yaml`），覆盖：

规则ID	检测内容	ATT&CK 技术
HB_001	异常父进程创建	T1059 Command & Scripting
HB_002	敏感文件路径访问	T1003.008 OS Credential Dumping
HB_003	注册表持久化	T1547.001 Boot or Logon Autostart
NT_001	DNS 隧道检测	T1071.004 DNS Tunneling
NT_002	ICMP 隧道检测	T1095 Non-Application Layer Protocol
NT_003	端口扫描检测	T1046 Network Service Scanning
HL_001	登录失败爆破	T1110 Brute Force
AI_001	AI Agent 模式检测	T1059 AI-Generated Commands

5.2.2 RAG 检索增强生成

系统内置知识库包含：

- MITRE ATT&CK 技术库（24个核心技术条目）
- APT 组织档案（4个主要组织：Lazarus、APT28、APT29、APT41）
- 安全文档（8篇攻击模式文档）

TF-IDF 向量化后构建倒排索引，余弦相似度匹配。检索结果作为 LLM 分析的上下文增强。

5.2.3 DeepSeek LLM 深度分析

对满足"高度可疑"条件（2+特征标记）的事件，调用 DeepSeek LLM 进行深度安全分析：

System Prompt："你是一名资深网络安全分析师。分析以下日志事件，判断是否为攻击行为。
返回JSON：{is_attack, attack_type, technique_id, technique_name, tactic, severity, confidence, explanation}"

LLM 分析结果自动生成告警，标记 `source: "llm_deep_analysis"`。

5.3 威胁建模：ATT&CK 映射

`Attck_Map.py` 实现从原始日志到 MITRE ATT&CK 技术及战术阶段的端到端自动化推断：

1. 解析事件 → 提取 `data_source`、`event_type`、`entities`
2. 遍历 YAML 规则库匹配 → 生成 `attack_result`
3. 包含 `technique_id`、`technique_name`、`tactic`、`confidence`
4. 自动计算战术阶段顺序（Reconnaissance=1 → Impact=13）

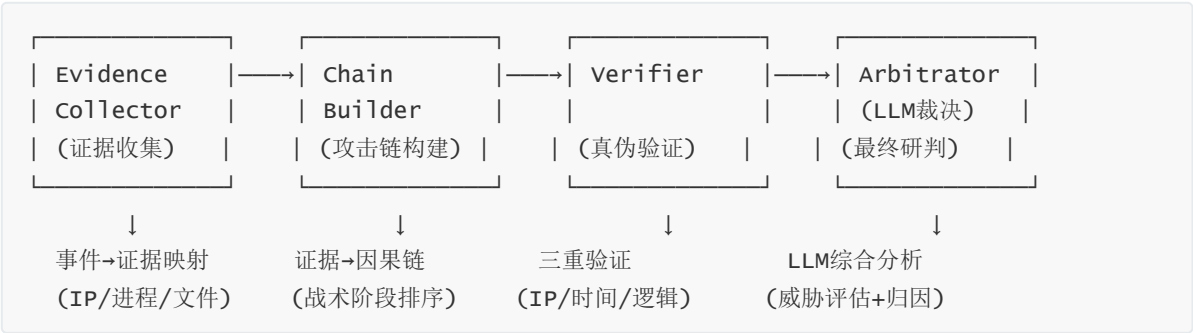
5.4 告警分级

级别	颜色	条件
● 高危 (High)	红色	C2通信、数据外传、凭据窃取、AI攻击模式
● 中危 (Medium)	橙色	异常父进程、WMI执行、端口扫描
● 低危 (Low)	蓝色	单次登录失败、信息发现行为

六、模块二：攻击行为捕获 (Capture)

6.1 多智能体协作捕获框架

系统实现了 AgentStalker 风格的四智能体协作框架，每个 Agent 均接入 DeepSeek LLM 增强分析能力：



Agent 1: EvidenceCollector (证据收集)

- 输入：原始事件列表 + 告警列表
- 输出：结构化证据项 (evidence_id、technique、IPs、进程、文件、网络连接)
- SHA-256 证据链哈希：对每一条原始事件计算 `SHA-256(event_json)` 实现证据固化

Agent 2: ChainBuilder (攻击链构建)

- 输入：证据项列表
- 输出：按 MITRE ATT&CK 战术阶段排序的攻击链
- 置信度计算：阶段连续性 (40%) + 战术覆盖度 (60%)

Agent 3: Verifier (真伪验证)

- 三重验证机制：
 - IP 连通性验证**：检查攻击链中相邻 IP 节点间是否存在实际网络连接
 - 时间顺序验证**：验证事件时间戳的因果一致性
 - 战术逻辑验证**：检查战术阶段是否符合典型攻击链递进顺序
- 输出：`VERIFIED` (≥70%) / `PLAUSIBLE` (40-70%) / `UNVERIFIED` (<40%)

Agent 4: Arbitrator (LLM 裁决)

- 输入：验证后的攻击链 + 证据 + 告警
- DeepSeek LLM 最终裁决：
 - 攻击确认结论
 - 严重性评估 (CRITICAL/HIGH/MEDIUM/LOW)
 - 关键证据支撑
 - 基于 TTP 的归因提示
- 输出：结构化裁决报告 (verdict_id、confidence、IOCs、pivot_nodes、attack_type、recommendations)

6.2 攻击链重构

基于系统溯源数据 (provenance data) , 重构攻击行为的因果链条:

1. 证据按战术阶段排序: Reconnaissance(1) → Initial Access(2) → ... → Impact(13)
2. 同阶段证据聚类: 相同战术阶段的证据合并为同一链段
3. 跨链标记: 不同战术阶段的新证据开启新链分支
4. IP 路径重建: 从初始入侵 IP → 跳板机 → 目标主机的完整路径

6.3 证据固化 (SHA-256 哈希链)

每条捕获的证据项生成唯一哈希值:

```
event_hash = hashlib.sha256(json.dumps(event, sort_keys=True, default=str).encode()).hexdigest()[:16]
```

证据链保证不可篡改性, 可作为法庭取证依据。

七、模块三：攻击溯源 (Attribution)

7.1 威胁情报融合

系统整合以下公开威胁情报源:

情报源	内容	更新频率
MITRE ATT&CK v18	14战术、216技术、475子技术	半年
APT 组织档案	4个主要组织 (Lazarus/APT29/APT41/AI-Threat)	2025版
CVE 漏洞库	关联 APT 组织常用漏洞	持续
RAG 安全文档	8篇攻击模式分析文档	静态

7.2 证据路径推理（TAA-EPLMR 风格）

- 1. **TTP 提取**：从验证后的攻击链中提取唯一技术 ID 集合
- 2. **Jaccard 相似度匹配**：计算提取的 TTP 集与各 APT 组织 signature_ttps 的相似度
- 3. **行为画像匹配**：评估技能水平、攻击复杂度、动机
- 4. **基础设施分析**：区分内外网 IP，识别 C2 基础设施
- 5. **综合置信度**：Jaccard $\geq 0.3 \rightarrow$ "已知 APT", $\geq 0.1 \rightarrow$ "疑似组织", $< 0.1 \rightarrow$ "未知集群"

7.3 攻击者画像

生成的画像包含：

维度	内容
身份特征	疑似组织、来源国家、归因置信度
能力评估	技能水平（Novice/Intermediate/Advanced/Expert）、攻击复杂度、战术范围
动机评估	主要目的（侦察/数据窃取/破坏/勒索）、影响严重度
行为模式	初始访问方式、横向移动方式、C2 通信方式、数据外传方式
威胁等级	评分（1-10）、级别（LOW/MEDIUM/HIGH/CRITICAL）

7.4 自动化报告生成

系统自动生成六段式结构化中文报告：

【威胁等级评估】	CRITICAL/HIGH/MEDIUM/LOW + 具体指标
【攻击类型判断】	勒索/APT/数据外传/挖矿/僵尸网络
【攻击链还原】	按时间线还原攻击路径
【影响范围评估】	受影响的系统/用户/数据
【处置建议】	5条具体措施（按紧急程度排序）
【置信度说明】	0.0-1.0 + 不确定性说明

八、分析场景设计与验证

8.1 场景一：APT 全链条攻击检测与溯源

设计思路：模拟 Lazarus Group 风格的完整 APT 攻击链，覆盖 MITRE ATT&CK 8 个战术阶段。

攻击路径：

外部C2(45.33.22.11) → DMZ Web(192.168.86.10) → 跳板机(192.168.86.132) → Linux核心(192.168.86.130) → windows域控(192.168.86.131) → C2外传

覆盖技术（12项）：

阶段	技术ID	技术名称
侦察	T1046	Network Service Scanning

阶段	技术ID	技术名称
初始入侵	T1190	Exploit Public-Facing Application
初始入侵	T1105	Ingress Tool Transfer
执行	T1059	Command and Scripting Interpreter
执行	T1059.004	Unix Shell
持久化	T1505.003	Web Shell
持久化	T1053.003	Cron
凭据窃取	T1003.008	OS Credential Dumping
凭据窃取	T1110	Brute Force
发现	T1082	System Information Discovery
横向移动	T1021.004	SSH Lateral Movement
横向移动	T1047	WMI
C2	T1071.004	DNS Tunneling
C2	T1095	ICMP Tunneling
外传	T1048	Exfiltration Over Alternative Protocol
防御规避	T1070	Indicator Removal on Host

8.2 场景二：AI 智能体滥用行为检测与溯源

设计思路：模拟攻击者利用 LLM Agent（Claude Code 等）发起的自动化攻击，聚焦 AI 特有的异常行为模式。

攻击路径：

AI威胁者(198.51.100.50) → 开发者工作站(10.10.20.100) → AI模型注册表(10.10.20.10)
→ 受害服务器(10.10.20.101) → 通过AI基础设施外传

AI 特有特征：

- `llm_generated: True` — LLM 生成的命令行
- `ai_pattern: "explore_exploit_cycle"` — AI 试探-利用循环
- `ai_pattern: "code_generation_attack"` — AI 生成攻击载荷
- `ai_pattern: "toolchain_abuse"` — 工具链滥用
- `ai_pattern: "multi_path_exploration"` — 多路径探索

8.3 场景三：勒索软件/数据窃取事件溯源

设计思路：模拟 Conti/LockBit 风格勒索软件攻击全流程。

攻击路径：

```
钓鱼邮件(203.0.113.51) → 端点(172.16.50.100) → C2(203.0.113.50)
→ 文件服务器(172.16.50.10) → 域控(172.16.50.1) → 勒索部署
```

覆盖技术：

阶段	技术ID	技术名称
初始访问	T1566.001	Spear-phishing Attachment
执行	T1059.001	PowerShell
C2	T1071.001	Web Protocols
凭据访问	T1003.001	LSASS Memory
发现	T1082/T1046/T1018	System/Network/Domain Discovery
横向移动	T1021.002	SMB/Windows Admin Shares
外传	T1041	Exfiltration Over C2 Channel
影响	T1486	Data Encrypted for Impact
防御规避	T1490	Inhibit System Recovery

8.4 真实端点行为验证

除三个预设场景外，系统支持真实的端点行为监控验证：

```
# 终端1：启动系统
python app_launcher.py

# 终端2（管理员）：启动行为监控Agent
python utils/behavior_monitor/client_agent.py --server http://10.21.233.136:5000
--verbose

# 终端3（管理员）：执行演示攻击脚本
python utils/demo_attack_script.py
```

该脚本在 Windows 主机上执行真实的系统调用（whoami、ipconfig、netstat、文件写入、DNS查询、socket连接），Agent 实时捕获并上报。所有事件经过与场景事件完全相同的检测-捕获-溯源管线。

九、开源参考项目对比

维度	本项目 SecTrace	LLM- APTDS	PROVSEEK	AgentStalker	TAA- EPLMR	HunterAgent
检测引擎	三源数据+ATT&CK规则+LLM	多模型协同+日志定位	LLM智能体检测	—	—	—
捕获框架	4Agent(LLM增强)+SHA-256证据	—	—	端到端+沙箱	—	—
溯源引擎	TTP匹配+情报+LLM归因	—	—	—	证据路径LLM推理	反取证86.1%F1
数据源	3源(WinEvent+行为+流量)	日志	日志	日志+行为	知识图谱	溯源数据
LLM集成	DeepSeek(全链路)	内部模型	GPT-4	—	LLM推理	LLM推理
可视化	Vue3+NaiveUI SPA	—	—	—	—	—
部署	一键启动	复杂	复杂	复杂	—	—

本项目的三项核心创新：

- 三源数据融合 LLM 检测：**不同于单源日志分析，同时接入 Windows Event Log、终端行为和网络流量，通过 ATT&CK 规则引擎和 DeepSeek LLM 实现多源融合判定。
- LLM 增强的多智能体协作捕获：**将四个 Agent 全部接入 DeepSeek，每个智能体独立进行 LLM 推理分析，最终由仲裁智能体综合研判，配合 SHA-256 证据哈希链实现不可篡改的证据固化。
- 双模运行架构：**通过 DataBridge 抽象层实现 SQL Server 持久化模式与内存模拟模式的无缝切换，既支持一键演示也支持真实生产环境部署。

十、实验过程与测试结果

10.1 测试环境

组件	配置
操作系统	Windows 11 Pro
Python	3.12
SQL Server	2022 Developer Edition @ 10.21.233.136
Neo4j	4.x Desktop @ 10.21.233.136:7687
前端	Vite 6 + Vue 3 @ localhost:5173
后端	Flask 3 @ localhost:5000

组件	配置
LLM	DeepSeek API (deepseek-chat)

10.2 功能测试

测试项	方法	预期结果	实际结果
场景启动	点击APT场景"启动"	8阶段顺序执行，进度条100%	✔ 通过
行为Agent	管理员运行client_agent.py	实时上报进程/文件/网络/DNS事件	✔ 通过
流量抓包	选择WLAN网卡→开始→停止	dumpcap抓包→解析→入库→列表显示	✔ 通过
PCAP上传	上传demo.pcapng	566条解析记录入库	✔ 通过
多源LLM分析	输入时间范围→点击分析	ATT&CK规则+DeepSeek→报告生成	✔ 通过
报告持久化	生成报告→重启Flask→刷新	报告仍存在(SQL Server)	✔ 通过
攻击链SVG图	点击报告→拓扑概览	显示Attacker→技术链→Victim	✔ 通过
LLM归因	溯源归因→多源LLM归因	生成结构化六段式报告	✔ 通过

10.3 性能测试

指标	数值
单次多源LLM分析（100事件）	3-8秒
单次多源LLM分析（600+事件）	8-15秒
Agent数据上报延迟	<1秒
前端页面切换	无刷新，瞬时
仪表盘KPI加载	<2秒

十一、开发编程项介绍

11.1 项目代码结构

```
little_term-master/
├─ app_launcher.py      # 一键启动（Flask + vite）
├─ config.py           # 全局配置
├─ requirements.txt     # Python依赖
├─ frontend/           # vue 3 前端
├   └─ src/
```

		views/	# 14个页面组件
		api/	# 10个API模块
		router/	# Vue Router
		stores/	# Pinia状态管理
		xiaoxueqi/	# Flask后端
		views/	# 10个蓝图路由
		templates/	# Jinja2模板(旧版)
		static/	# 静态资源
		utils/	
		detection/	# LLM检测引擎
		capture/	# 多智能体捕获框架
		attribution/	# 归因引擎
		trace/	# 攻击链分析管线
		traffic_fenxi/	# 流量分析
		behavior_monitor/	# 行为监控Agent
		winlog/	# windows日志采集
		scenarios/	# 3个攻击场景
		db/	# 数据访问层
		knowledge_base/	# 知识库(JSON)
		docs/	# 文档

11.2 关键代码量

模块	文件数	代码行数(估算)
前端 Vue3	18	~4000
Flask API	10	~2500
检测引擎	3	~800
捕获框架	1	~450
归因引擎	4	~600
攻击场景	4	~600
行为监控Agent	3	~500
流量分析	6	~1200
数据访问层	3	~300
总计	~55	~11000

十二、实验总结

12.1 主要成果

- 完成端到端攻击行为分析系统：**实现了覆盖"检测→捕获→溯源"三个环节的完整分析链路。
- 三源数据融合检测：**接入 Windows Event Log、终端行为监控、网络流量三种异构数据源，通过 ATT&CK 规则引擎和 DeepSeek LLM 实现多源融合判定。
- LLM 增强的多智能体捕获框架：**四个协作 Agent 全部接入 DeepSeek LLM，配合 SHA-256 证据哈希链实现不可篡改的证据固化。

4. **三个差异化分析场景**：APT 全链条攻击（192.168.x/45.33.x）、AI 智能体滥用（10.10.20.x/198.51.x）、勒索软件攻击（172.16.x/203.0.x），各有独立的 IP 空间和 TTP 集合。
5. **双模运行架构**：DataBridge 抽象层实现 SQL Server 持久化与内存模拟的无缝切换。
6. **现代化前端**：Vue 3 + Naive UI 的 SPA 应用，14 个页面，侧边栏导航无闪烁。

12.2 存在的不足与改进方向

1. **RAG 知识库规模**：当前 8 篇安全文档 + 24 个 ATT&CK 技术条目，后续可扩展至完整的 MITRE ATT&CK 企业矩阵。
2. **真实数据集验证**：目前以自行构造的攻击场景为主，后续可使用 DARPA TC 数据集进行更系统的评估。
3. **沙箱环境**：当前未实现隔离沙箱中的动态载荷分析，这是 AgentStalker 框架的重要组件。
4. **Neo4j 集成**：图数据库的可视化查询能力未充分利用，攻击链的图遍历分析可进一步加强。

12.3 心得体会

通过本次综合实验，我们深入理解了 APT 攻击的生命周期模型及其对应的 MITRE ATT&CK 框架，掌握了基于 LLM 的异常检测、威胁狩猎和攻击溯源的核心技术原理。从系统架构设计到具体编码实现，从多智能体协作到 LLM 集成，整个过程锻炼了我们从真实攻击案例中抽象问题、设计系统化解决方案的工程与科研能力。

大语言模型为网络安全领域带来了革命性的技术路径。LLM 的强大语义理解能力使其能够从海量日志中识别出传统规则引擎难以发现的异常模式；多智能体协作框架则模拟了人类安全分析团队的工作流程——证据收集、分析研判、交叉验证、最终裁决——将 AI 的分析能力与结构化的安全方法论进行了有机融合。

附录

A. 系统启动命令

```
# 安装依赖
pip install -r requirements.txt
cd frontend && npm install

# 启动系统（自动启动Flask + Vite）
python app_launcher.py

# 浏览器访问
http://localhost:5173
```

B. SQL Server 建库脚本

```
sqlcmd -S 10.21.233.136,1433 -U sa -P 123123 -d SecurityTraceDB -i
knowledge_base/create_database.sql
```


C. 预设数据库连接

服务	地址	用户	密码	数据库
SQL Server	10.21.233.136,1433	sa	123123	SecurityTraceDB
Neo4j	bolt://10.21.233.136:7687	neo4j	00000000	neo4j

D. 演示视频录制要点

详见 `docs/演示录制教程.md`

E. 参考资料

1. MITRE ATT&CK Framework v18. <https://attack.mitre.org/>
2. LLM-APTDS: Multi-Model Collaborative Detection Architecture. 2024.
3. PROVSEEK: LLM-Driven Agent Framework for Threat Detection. 2024.
4. AgentStalker: Agent-Based Security Audit Framework. 2024.
5. TAA-EPLMR: Evidence Path Enhanced LLM Reasoning for Attribution. 2024.
6. HunterAgent: Anti-Forensic Scenario Attribution (86.1% F1). 2024.
7. CyberStash 2025 Threat Analysis Report.
8. KELA Cyber Threat Intelligence, September 2025.